Báo cáo tuần 4

Chi tiết giải pháp đề xuất
WAF Log Analyzer

Nhóm G21 IT6027 lớp 26.1A01

2 tháng 10 năm 2026

Nguồn	`solution-design` v1.6, `application.yaml`, `RiskScorer`, `IncidentManager`, seed rule, probe
Việc tuần này	Mô tả giải pháp theo khối, tham số, ví dụ số, và chỗ đứng so với bài cùng hướng
Số liệu	Coverage offline và weight rule **đã có trong repo**. Replay 10 000 dòng **chưa đo**

Tuần 3 hỏi coverage trên log có lệch quá 15 điểm so với held-out hay không (RQ1), số incident có giảm ít nhất 15% so với một alert một incident hay không (RQ2), và $p95$ tới SSE có dưới 5 giây trên luồng lớn hay không (RQ3). Báo cáo này không trả số cho ba câu đó. Báo cáo này mô tả giải pháp dùng để trả, ở mức đủ để dựng lại cùng tham số.

Giải pháp là log analyzer đứng sau Nginx. Detector là 14 regex đã qua cổng precision $\geq 0{,}80$ và FPR $\leq 0{,}02$. Điểm 0–100 quyết định alert. Incident chỉ mở theo IMMEDIATE hoặc AGGREGATE. LLM đọc incident sau khi transaction ingest đã commit và không được đổi điểm.

1. Bài toán từng khối phải đóng

Bảng 1: Khối giải pháp, việc không làm, và câu hỏi tuần 3.

Khối	Việc làm	Việc không làm	Câu hỏi
Rule engine	Khớp `query` hoặc `path`; lưu hit, weight, evidence	Không gọi LLM, không chặn request	RQ1
Scoring	Cộng weight, bonus tần suất và status, cắt 100	Không học lại trọng số	RQ1, ngưỡng RQ2
Alert	Một alert mỗi event khi score $\geq$ ngưỡng app	Không mở incident	Mẫu số RQ2
Incident	Gộp theo `(app_id, client_ip)` trong 5 phút	Không giải thích, không đổi score	RQ2
SSE + SOC	Đẩy alert, incident; triage ACK/CLOSED	Trình duyệt không đọc Kafka	RQ3
Ollama	Giải thích từ tối đa 5 alert đã có hit	Không nằm trên thread Kafka	Ngoài đồng hồ RQ3
Probe lab	24 payload nhãn alert và 50 request sạch	Không đo replay 10 000 dòng	Tầng S

2. Luồng một request và tham số đã khóa

Nginx JSON → Filebeat → Kafka `raw-web-logs` → `WebEvent` → 14 rule (cache Redis) → `DetectionHit` → score, cửa sổ 5 phút theo `client_ip` → Alert nếu score ≥ 60 → `IncidentManager` (W=5 phút, K=3)

→ topic `security-alerts` và SSE → sau commit, `@Async`, Ollama chỉ khi incident vừa tạo và profile `llm` bật.

Bảng 2: Tham số trong `application.yaml` và schema app.

Tham số	Giá trị	Hệ quả
`scoring.window-minutes`	5	`freq_bonus` nhìn hit cùng IP trong 5 phút
`incident.window-minutes`	5	Incident OPEN cũ hơn cửa sổ bị đóng trước khi promote
Ngưỡng gom K	3	Dưới 3 alert MEDIUM/HIGH cùng khoá thì chưa có incident
`risk_threshold`	60	Score 59 không thành alert
Severity	<40 LOW, 40–69 MEDIUM, 70–84 HIGH, ≥ 85 CRITICAL	Chỉ CRITICAL đi nhánh IMMEDIATE
`llm.enabled`	false mặc định	`SKIPPED`, không HTTP
`llm.model`	`llama3.2`	Chỉ khi bật profile
`llm.timeout-seconds`	20	Quá hạn thì FAILED; incident vẫn xem được
`llm.max-alerts`	5	Prompt nhận tối đa 5 alert mới nhất
JWT access	480 phút	Một ca demo không login lại giữa chừng
Redis rule đang bật	TTL 10 phút, xóa key khi sửa rule	Weight mới có hiệu lực không cần đợi hết TTL
Kafka `acks`	1	Leader ghi xong là producer trả

TTL 10 phút là lưới an toàn. Cache xóa key Redis khi admin sửa rule, nên event sau dùng pattern mới. Cột `detection_hits.weight` là bản sao lúc khớp; sửa weight sau không viết lại hit cũ.

3. Giải pháp phát hiện

3.1 Mười bốn rule và ngưỡng 60

Seed rule ghi `source = AI_MINED`, phiên bản `1.0.0`. Bốn rule path traversal soi `path`. Sáu rule SQLi và bốn rule XSS soi `query`. Không có rule command injection (HttpParams có 89 mẫu cmdi) và không có rule đọc POST body.

Bảng 3: Weight và khả năng tự thành alert trên HTTP 200, khi cửa sổ chưa có hit khác.

Nhóm rule	Weight	Trên HTTP 200
SQLI-TIME-001	60	Đạt ngưỡng, severity MEDIUM
SQLI-UNION-001, PT-DOUBLE-001, XSS-SCRIPT-001	55	Chưa alert
SQLI-STACKED-001, PT-ENCODED-001, XSS-JSURI-001	50	Chưa alert
PT-BACKSLASH-001, PT-DOTDOT-001, XSS-EVENT-001	45	Chưa alert
SQLI-BOOLEAN-001/002, XSS-ENCODED-001	40	Chưa alert
SQLI-COMMENT-001	35	Chưa alert

Chỉ TIME-001 tự tạo alert khi response là 200 và chưa có hit khác. UNION, thẻ script, hay `../` cần thêm hit cùng request, hoặc `status_bonus`, hoặc `freq_bonus`, mới qua 60. Khớp rule yếu vẫn được ghi hit, nhưng chưa thành việc SOC. Khác một bộ chữ ký "khớp là chặn" của WAF inline.

Coverage CSV đã đo, gắn với bộ weight này chứ không phải số mới: path traversal held-out 48,00% trên 175 và adversarial 51,36% trên 808; SQLI 50,52% trên 6 598 và 49,58% trên 32 851; XSS 68,12% trên 229 và 69,85% trên 1 111. FPR benign cả ba category bằng 0. `PT-DOUBLE-001` nặng 55 điểm nhưng recall held-out

$0/175$. Trọng số cao không đồng nghĩa phủ nhiều mẫu. Rule được giữ vì adversarial có $2/808$ hit và precision trên benign vẫn 1. RQ1 phải tách coverage khỏi trọng số.

3.2 Công thức điểm

$$\begin{aligned}
\text{base} &= \min\big(100,\ \textstyle\sum \text{weight}\big),\\
\text{freq_bonus} &= \begin{cases} 0 & \text{nếu số hit cùng IP trong 5 phút} < 2,\\ \min\big(20,\ 2(\text{count}-1)\big) & \text{ngược lại,}\end{cases}\\
\text{status_bonus} &= 5 \text{ nếu status} \in \{403, 404, 500\} \text{ và base} > 0,\\
\text{score} &= \min(100,\ \text{base} + \text{freq_bonus} + \text{status_bonus}).
\end{aligned}$$

`freq_bonus` đếm dòng hit, không đếm request. Trần 20 đạt khi có 11 hit trong cửa sổ, vì $2 \times (11-1) = 20$. Comment SQL weight 35, dù trần tần suất và status, tối đa $35 + 20 + 5 = 60$, đúng ngưỡng MEDIUM, không thành CRITICAL.

Bảng 4: Bốn tình huống tính theo `RiskScorer`.

Tình huống	Score	Alert	Severity	Việc SOC
`q=apple`, không hit, HTTP 200	0	Không	LOW	Không incident
Một hit TIME-001, HTTP 200, một hit trong cửa sổ	60	Có	MEDIUM	Chưa incident nếu là alert MEDIUM thứ nhất hoặc thứ hai
TIME-001 và UNION-001 cùng request	100	Có	CRITICAL	IMMEDIATE
Ba TIME-001 cùng IP trong 5 phút	60, 62, 64	3	MEDIUM	Lần 3 đủ K=3, một incident AGGREGATE

Ba request TIME cùng IP: baseline một-một ra 3 incident, giải pháp ra 1. Mức giảm $(3-1)/3 = 66{,}7\%$, trên mốc 15% của RQ2, khi detector đúng weight 60 và ba request nằm trong một cửa sổ. Một TIME từ một IP lạ chỉ còn alert, `incident_id` null. Đó là K=3, không phải sót promote.

UNION-001 trên HTTP 404 thành $55 + 5 = 60$, MEDIUM. Cùng payload trên HTTP 200 vẫn 55, không alert. Giải pháp nhạy với mã HTTP của Juice Shop, không chỉ với chuỗi payload.

4. Giải pháp Incident

`IncidentManager.promote` chạy sau khi alert đã có. LOW bỏ qua. Alert đã gắn incident thì không xét lại.

1. Tìm incident `OPEN` cùng `(app_id, client_ip)`.
2. Nếu `opened_at` cũ hơn 5 phút, đóng incident đó và ghi work note, coi như không còn incident mở.
3. Nếu còn incident mở trong cửa sổ, gắn alert vào. Tăng `alert_count`, severity lấy max, score lấy max. Không tạo incident mới và không gọi explain lại.
4. Nếu chưa có incident mở và severity là CRITICAL, tạo incident `promote_reason = IMMEDIATE`.
5. Nếu MEDIUM hoặc HIGH, đếm alert cùng khoá, chưa gắn incident, trong 5 phút. Đủ 3 thì tạo `AGGREGATE` và gắn cả nhóm. Chưa đủ thì alert đứng một mình.

Explain chỉ xếp hàng khi incident vừa được chèn. Gắn thêm alert vào incident cũ không gọi Ollama. Work note nguồn `SYSTEM` ghi lúc promote và lúc gắn thêm, nên UI còn vết khi model tắt.

Burst đã tính ở tuần 3 vẫn khớp luật này nếu severity sau scoring đúng khoảng: 6 CRITICAL cùng IP thành 1 incident IMMEDIATE, 9 MEDIUM thành 3 incident AGGREGATE, 3 HIGH thành 1. Tổng 18 alert thành 5 incident, giảm 72,2%. Với bộ weight hiện tại, một payload TIME đơn không vào nhóm CRITICAL. Sáu CRITICAL chỉ xảy ra khi một request ăn nhiều rule (TIME + UNION = 100) hoặc khi tổng weight và bonus chạm 85. RQ2 phải dùng severity sau scoring, không dùng nhãn "payload nặng" thay cho score.

5. Thời gian thực, mặt SOC, và LLM

Trình duyệt không subscribe Kafka. Luồng alert đẩy cả sự kiện chưa đủ K. Luồng incident đẩy incident mới, alert được gắn, và đổi trạng thái giải thích. Hai đường SSE tương ứng là alerts và incidents dưới `/api/stream`.

Dashboard React có đăng nhập JWT, overview lọc `app_id` (timeline, top loại tấn công, top IP, top path), danh sách alert, danh sách incident, và chi tiết incident. Chi tiết hiện từng hit gồm mã rule, category, weight, evidence, cùng ba thao tác: xác nhận (`ACK`), đóng (`CLOSED`), giải thích lại. Dòng cố định trên khối giải thích: "AI hỗ trợ, có thể không chính xác."

Đồng hồ RQ3 dừng lúc event SSE alert tới. Timeout Ollama 20 giây dài hơn hạn 5 giây. Cộng hai đồng hồ thì mọi ca bật LLM đều trượt RQ3 dù detect đã xong. Thiếu JWT thì `GET /api/incidents` trả 401. Auth không đổi công thức điểm.

Bảng 5: Khối Ollama, mặc định tắt.

Việc	Cách làm
Khi nào gọi	Incident mới tạo, sau `AFTER_COMMIT`, thread `@Async`
Khi tắt	`SKIPPED`, không HTTP, alert và incident vẫn hiện
Khi lỗi hoặc quá 20 giây	`FAILED`, lỗi cắt 500 ký tự, consumer không nhận exception
Retry	`POST /api/incidents/{id}/explain` trả 202, không giữ connection chờ model
Prompt	Tối đa 5 alert. Title 180 ký tự, path 180, query 240, evidence 180, IP 64
Đầu ra	Cắt 4 000 ký tự. `CONFIDENCE: LOW|MEDIUM|HIGH`; thiếu dòng thì MEDIUM
Việc model không làm	Không ghi score, không sửa rule, không đóng incident

6. Dữ liệu demo tầng S

Bảng 6: Hai lệnh đều đi qua Nginx, không gửi POST body.

Lệnh	Số	Nhãn
`scenarios.yaml` + `run.sh`	30 scenario	24 `expected: alert` (8 SQLi, 8 XSS, 8 path traversal), 6 `expected: clean`
`browse_clean.sh`	50 path	Trang chủ, search hợp lệ, whoami, 10 sản phẩm, asset tĩnh

24 probe nhãn alert không đồng nghĩa 24 alert sau scoring. Payload chỉ khớp rule weight 35–55 trên HTTP 200 nằm dưới ngưỡng. Ground truth kỳ vọng và alert thực tế là hai cột; tuần đo mới đối chiếu. Runner ghi rõ chỉ probe Juice Shop tự host. Tầng L của tuần 3 (10 000 dòng, 80% benign, 20% tấn công, 20 sự kiện/giây) không nằm trong runner này. Runner là tầng S, sát thiết kế khoảng 50 request sạch và 30 probe.

7. Chỗ đứng so với hướng tương tự

Giải pháp chấp nhận kém hơn bài báo inline ở chỗ không chặn request, không thấy body, và coverage SQLi held-out 50,52% không phải accuracy phân loại trên CSV. Đổi lại, mỗi hit truy được về mã rule và evidence, và đồng hồ detect không chứa thời gian model.

Bảng 7: Cùng một việc, hai cách làm.

Hướng	Cách của họ	Cách của giải pháp này
WAFBooster [2]	True rejection 21% → 96% trên 8 WAF; shadow RNN vá chữ ký inline	14 regex Java, weight 35–60, mine offline, không đo true rejection
GenXSS [3]	Khoảng 15 SecRule, khoảng 86% bypass XSS, GPT-4o viết rule	Ba category, LLM online chỉ giải thích, `llama3.2`, timeout 20 giây
ML-WAF trên CSIC [1]	Một nhãn cho cả request, khoảng 61 000 dòng không timestamp	Hit có mã rule. Cửa sổ K và W cần thời gian; lab Juice có sẵn trên log Nginx
SIEM một alert một case	Mỗi cảnh báo là một việc	3 alert MEDIUM cùng IP trong 5 phút thành 1 incident
LLM triage mọi alert	Hỏi model trên alert đơn	Model chạy khi incident vừa tạo. Hai alert chưa đủ K không phát sinh một lần gọi

8. Cơ chế nào sẽ bị đo

Chưa có kết quả chạy RQ1–RQ3 ở đây. Bảng dưới chỉ nối câu hỏi với cơ chế.

Bảng 8: Câu hỏi tuần 3 và tham số sẽ bị đối chiếu.

Câu hỏi	Cơ chế	Tiêu chí đã chốt
RQ1	14 regex trên access log, không đổi weight giữa chừng	SQLI $\geq$ 35,52%, XSS $\geq$ 53,12%, PT $\geq$ 33,00%, FPR $\leq$ 2%
RQ2	K=3, W=5, ngưỡng 60, CRITICAL $\geq$ 85	Giảm incident $\geq$ 15% so với đếm một-một; CRITICAL bỏ sót = 0
RQ3	Kafka → score → alert → SSE; LLM sau commit	$p95 < 5$ giây tại $\geq$ 20 sự kiện/giây, trên $\geq$ 10 000 dòng

Nếu ba probe TIME cùng IP ra 3 alert và 1 incident, mức giảm trên burst đó là 66,7%. Nếu nhiều probe trong số 24 nhãn alert có score dưới 60, mẫu số RQ2 nhỏ đi và kết luận phải ghi số alert thực. Nếu $p95$ đo tới `READY` của Ollama, số đó không thuộc RQ3.

9. Kết luận

Giải pháp đề xuất là pipeline out-of-band với tham số đã khóa: 14 rule `AI_MINED`, điểm cắt 100, ngưỡng 60, bonus tần suất tối đa 20, bonus status 5, incident K=3 trong 5 phút, SSE tách khỏi Ollama. Chỉ SQLI-TIME-001 (weight 60) tự tạo alert trên HTTP 200. Các rule 35–55 cần hit cộng dồn hoặc bonus. LLM `llama3.2` timeout 20 giây, tối đa 5 alert, cắt thân 4 000 ký tự, tắt thì `SKIPPED`. Demo tầng S có 30 scenario (24 kỳ vọng alert, 6 sạch) và 50 request `browse_clean`.

WAFBooster và GenXSS không được lấy làm chỉ tiêu 96% hay khoảng 86%. Trên ba request TIME cùng IP trong 5 phút, giải pháp ra một incident thay vì ba. Coverage offline và các mức giảm 66,7% cùng 72,2% là mốc thiết kế. Bảng FP/FN trên Juice và replay 10 000 dòng thuộc lần đo sau.

Tài liệu

[1] HTTP dataset CSIC 2010. Viện An ninh Thông tin, CSIC, 2010. Khoảng 36 000 request thường và 25 000 request bất thường.

[2] Wu và cộng sự. WAFBooster. arXiv:2501.14008, 2025. True rejection 21% lên 96% trên 8 WAF.

[3] Babaey và Ravindran. GenXSS. arXiv:2504.08176, 2025. Khoảng 15 rule ModSecurity, khoảng 86% bypass XSS.

[4] Nhóm G21. Solution design v1.6, seed rule V2, và báo cáo tuần 3. Tham số $K{=}3$, $W{=}5$ phút, ngưỡng 60, coverage held-out.